GLOBALTECH INC.

ADVANCED GRC PHISHING SIMULATION & QUANTITATIVE RISK ANALYSIS

Laboratory 3 | Practical Assessment Report

Student name	**Hilda Odein Joshua-Jack**
Registration number	C11/26/CGRCE/17247
Date	1 November 2026
Organisation	GlobalTech Inc.

1. Executive Summary

This report analyses three phishing simulation campaigns involving 430 email recipients. The campaigns generated 354 opens, 257 link clicks, 105 credential submissions and 38 personal-data entry events. The pooled credential submission rate was 24.42% (105/430). Campaign B, the IT System Password Reset simulation, recorded the highest credential submission rate at 30%. Campaign C, which targeted executives and assistants, recorded the highest open rate (90%) and click-through rate (75%).

The supplied worked example estimates $652.5 million in annual losses by treating 150 projected breach events as independent incidents. The simulation data do not establish that each credential submission creates a separate breach. The $652.5 million figure is therefore not a defensible Annualised Loss Expectancy (ALE). For illustration, this report uses one relevant attack-scenario occurrence per year and the supplied 25% probability of a major breach following that scenario. With a $4.35 million single-loss estimate, the resulting scenario-based expected annual loss is $1,087,500. This is conditional on an explicit analyst assumption, not a verified forecast.

The recommended response is a layered programme combining enterprise MFA, targeted security awareness, stronger executive verification procedures, email protection and monitoring. The workbook supplied with this report contains the underlying data, formulas, assumptions and calculations.

2. Scope, Data and Method

The analysis uses only the three simulation datasets and organisational assumptions supplied in the laboratory brief. No live phishing activity was conducted and no credentials were collected. Campaign A targeted employees with an HR bonus lure; Campaign B targeted employees with an IT password-reset lure; Campaign C targeted executives and assistants with an urgent CEO document-review lure.

Fundamental rates use emails sent as the denominator. Conversion rates use the preceding funnel stage as the denominator: opened emails for open-to-click conversion, clicked links for click-to-credential conversion, and clicked links for click-to-personal-data-entry conversion.

3. Campaign Metrics

Table 1 presents the calculated campaign metrics. Percentages are rounded to two decimal places.

Campaign	Sent	Opened	Clicked	Credentials	Data entry	Open rate	CTR	Credential rate
A	100	82	47	18	5	82.00%	47.00%	18.00%
B	250	200	150	75	25	80.00%	60.00%	30.00%

C	80	72	60	12	8	90.00%	75.00%	15.00%
Overall	430	354	257	105	38	82.33%	59.77%	24.42%

Data-entry rates, using emails sent as the denominator, were 5.00% for A, 10.00% for B and 10.00% for C. The aggregate rate was 8.84% (38/430).

3.1 Conversion Rates

Conversion	Campaign A	Campaign B	Campaign C
Open-to-click	57.32% (47/82)	75.00% (150/200)	83.33% (60/72)
Click-to-credential	38.30% (18/47)	50.00% (75/150)	20.00% (12/60)
Click-to-data-entry	10.64% (5/47)	16.67% (25/150)	13.33% (8/60)

Campaign C produced the greatest open-to-click conversion, while Campaign B produced the greatest click-to-credential conversion. Campaign B is therefore the clearest priority for credential-theft mitigation. Click-through must not be reported as credential submission: the two measures describe different stages of the attack funnel.

4. Organisational Exposure and Financial Model

4.1 Scaled credential-submission projections

If each campaign's observed credential submission rate were applied to all 2,000 employees, the simple projections would be 360 submissions for A (2,000 × 18%), 600 for B (2,000 × 30%) and 300 for C (2,000 × 15%). These are extrapolations, not confirmed compromised accounts. They assume that each campaign's target group and conditions represent the wider workforce. That assumption is particularly weak for Campaign C because it targeted executives and assistants rather than a general employee sample.

4.2 Correct interpretation of breach probability

The brief multiplies 600 projected credential submissions by 25% and labels the result 150 breaches. Although the arithmetic is correct, the interpretation is not supported. It assumes that each submission independently causes a major breach with a 25% probability. Multiple compromised accounts may contribute to one incident; credentials may be invalid or unusable; and preventive controls may stop exploitation. The data do not identify unique compromised accounts, actual exploitation, incident counts or independence between outcomes.

4.3 Illustrative SLE and ALE

The supplied Single Loss Expectancy (SLE) is $4,350,000. The brief does not provide historical annual incident frequency. To demonstrate ALE transparently, this report adopts an explicit illustrative assumption of one relevant attack-scenario occurrence per year (ARO = 1) and a 25% probability of a major breach following that scenario.

ALE = SLE × ARO × probability of major breach

$$ALE = \$4{,}350{,}000 \times 1 \times 0.25 = \$1{,}087{,}500$$

This expected-loss estimate is conditional on the one-scenario-per-year assumption. It should not be represented as a validated forecast. A defensible organisational ALE requires a measured or justified annual occurrence frequency and a clearly defined loss event.

5. Control Cost-Benefit Analysis

Control costs and effectiveness percentages are treated as scenario assumptions supplied by the brief, not verified industry benchmarks. The illustrative baseline ALE used for comparison is $1,087,500.

Control	Cost	Assumed effectiveness	Risk reduction	Net benefit	ROI

MFA	$90,000	99.9%	$1,086,412.50	$996,412.50	1,107.13%
Security awareness training	$100,000	60%	$652,500	$552,500	552.50%
Email filtering	$50,000	Not supplied	Not quantifiable	Not quantifiable	Not quantifiable

MFA: cost = 2,000 × $45 = $90,000. Modelled risk reduction = $1,087,500 × 99.9% = $1,086,412.50. Residual ALE = $1,087.50. Net benefit = $1,086,412.50 − $90,000 = $996,412.50. ROI = (risk reduction − cost) / cost × 100 = 1,107.13%.

Training: cost = 2,000 × $50 = $100,000. Campaign B's click-through rate is 60%. A 60% reduction gives a new click-through rate of 60% × (1 − 0.60) = 24%, not 12%. Campaign B's click-to-credential conversion remains 50% under the stated modelling assumption, so the projected credential submission rate becomes 24% × 50% = 12%. Across 2,000 employees this is 240 projected submissions. For the illustrative financial comparison, a 60% reduction in expected loss is assumed: risk reduction = $1,087,500 × 60% = $652,500; residual ALE = $435,000; net benefit = $552,500; ROI = 552.50%.

The training calculation assumes that click reduction translates proportionately into reduced expected loss and that post-click conversion remains constant. Both assumptions require validation. MFA's 99.9% effectiveness assumption is also highly optimistic if interpreted as reducing total breach impact; MFA mitigates account takeover but does not eliminate all phishing, session hijacking, malware or other compromise routes. MFA and training benefits may overlap, so their risk reductions must not simply be added.

5.1 Break-even analysis

The brief gives a total proposed investment of $490,000. Dividing this by the assumed $4,350,000 cost of one major breach gives $490,000 / $4,350,000 = 0.1126 breach-equivalents. In practical terms, preventing one full breach would exceed the investment cost under the supplied loss assumption. This is a simple break-even comparison, not evidence that the proposed controls will prevent a breach.

6. Statistical Analysis

The laboratory specifies the 95% normal-approximation interval: $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$. The calculated intervals are:

Campaign	p	n	Margin of error	95% confidence interval
A	18%	100	7.53%	10.47%–25.53%
B	30%	250	5.69%	24.31%–35.69%
C	15%	80	7.82%	7.18%–22.82%

Campaign A: $0.18 \pm 1.96 \times \sqrt{[0.18 \times 0.82 / 100]} = 18\% \pm 7.53\%$, giving 10.47% to 25.53%. Campaign B: 30% ± 5.69%, giving 24.31% to 35.69%. Campaign C: 15% ± 7.82%, giving 7.18% to 22.82%.

The normal approximation is presented because it is the method specified in the brief. It may be less reliable for smaller samples or proportions near zero or one; Wilson intervals would be a useful sensitivity check. The campaigns target different groups and may not be random, independent samples from one common population. Confidence intervals describe sampling uncertainty under assumptions; they do not guarantee future campaign outcomes. Overlap or non-overlap of these intervals is not, by itself, a formal test of statistical significance.

7. Risk Assessment and Priorities

Campaign	Credential rate	Qualitative rating	Priority	Recommended action
A – HR Bonus	18%	High	2	Targeted HR-themed awareness, reporting practice and repeat simulation.
B – IT Password Reset	30%	Critical	1	Prioritise MFA, identity monitoring, password-

				reset verification and targeted training.
C – CEO Document Review	15%	High	2	Executive account protection, out-of-band verification and targeted simulations.

Ratings are qualitative judgements, not statistically derived risk scores. Campaign B is first priority because it has the highest observed credential submission rate. Campaign C remains high priority because executive and assistant accounts may have privileged access or facilitate sensitive transactions. The brief does not provide sufficient information to assign defensible campaign-specific dollar losses; one common breach-cost assumption cannot establish different financial exposures for the three campaigns.

8. Corrections to Supplied Worked Examples

Supplied statement	Correction / issue	Reason
Overall credential theft rate = 22.1%	105 / 430 = 24.42%	Use total credential submissions divided by total emails sent.
Training new click-through rate = 12%	Correct rate = 24%	60% × (1 − 60%) = 24%; 12% is the projected credential submission rate only if 50% post-click conversion persists.
150 expected breaches	Not established	Credential submissions are not automatically independent breach incidents.
ALE = $652.5 million	Unsupported	Annual occurrence frequency and independent breach events are not established.
MFA ROI = 724,175%	Not defensible as presented	Uses the unsupported $652.5m baseline and assumed 99.9% effectiveness.
Industry averages in executive table	Exclude unless sourced	No supporting source or methodology is supplied.
Email filtering risk reduction = $130.5m	Not quantifiable from supplied data	Effectiveness percentage and a defensible baseline are missing.

9. Recommendations

1. Implement phishing-resistant MFA where feasible, prioritising privileged, executive and remote-access accounts.
2. Deliver targeted awareness and simulation exercises based on the attack themes that produced the highest conversion rates.
3. Require out-of-band verification for password resets, urgent executive requests, payment changes and sensitive document access.
4. Strengthen email authentication and filtering, and measure the control using delivered phishing rate, click rate, credential submission rate and false-positive rate.
5. Improve identity monitoring, suspicious sign-in detection, session revocation and incident response procedures.
6. Track repeat-simulation performance and report trends by business unit and role, while protecting employee privacy and avoiding punitive use of simulation results.
7. Replace illustrative assumptions with actual incident frequency, unique compromised-account data, validated breach costs and measured control effectiveness.

10. Limitations and Conclusion

The dataset contains only three simulations and does not establish random sampling, representativeness, repeated exposure, unique compromised accounts, successful exploitation or actual financial loss. Campaign C's executive/assistant population is not directly comparable with the employee groups in A and B. The breach-cost

estimate and control-effectiveness figures are scenario assumptions. The annual occurrence assumption used for ALE is an analyst assumption introduced solely to demonstrate a transparent calculation.

The simulations identify a clear need to strengthen protection against credential phishing, particularly for the IT password-reset scenario and high-impact executive accounts. GlobalTech should prioritise layered identity controls, targeted awareness, verification processes and ongoing measurement. Management should treat the financial outputs as conditional decision-support estimates and refine them as reliable operational and incident data become available.

Appendix A. Formula Reference

- Open rate = emails opened / emails sent × 100
- Click-through rate = links clicked / emails sent × 100
- Credential submission rate = credentials submitted / emails sent × 100
- Data entry rate = personal-data entry points / emails sent × 100
- Open-to-click conversion = links clicked / emails opened × 100
- Post-click credential conversion = credentials submitted / links clicked × 100
- Single Loss Expectancy (SLE) = estimated cost of one defined loss event
- Annualised Loss Expectancy (ALE) = SLE × annual rate of occurrence (ARO); when using event probability, expected loss = SLE × scenario frequency × probability of loss
- ROI = (estimated risk reduction − control cost) / control cost × 100
- 95% normal-approximation CI = $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$